



Instituto Tecnológico Superior De Jalisco

Unidad Académica

La Huerta

Ingeniería En Sistemas Computacionales

ISIC-2010-224

DevOps Integración y Prácticas Continuas

Reporte

Proyecto Integrador

Alumno

Marco Antonio Flores Pelayo

30 de Mayo de 2026

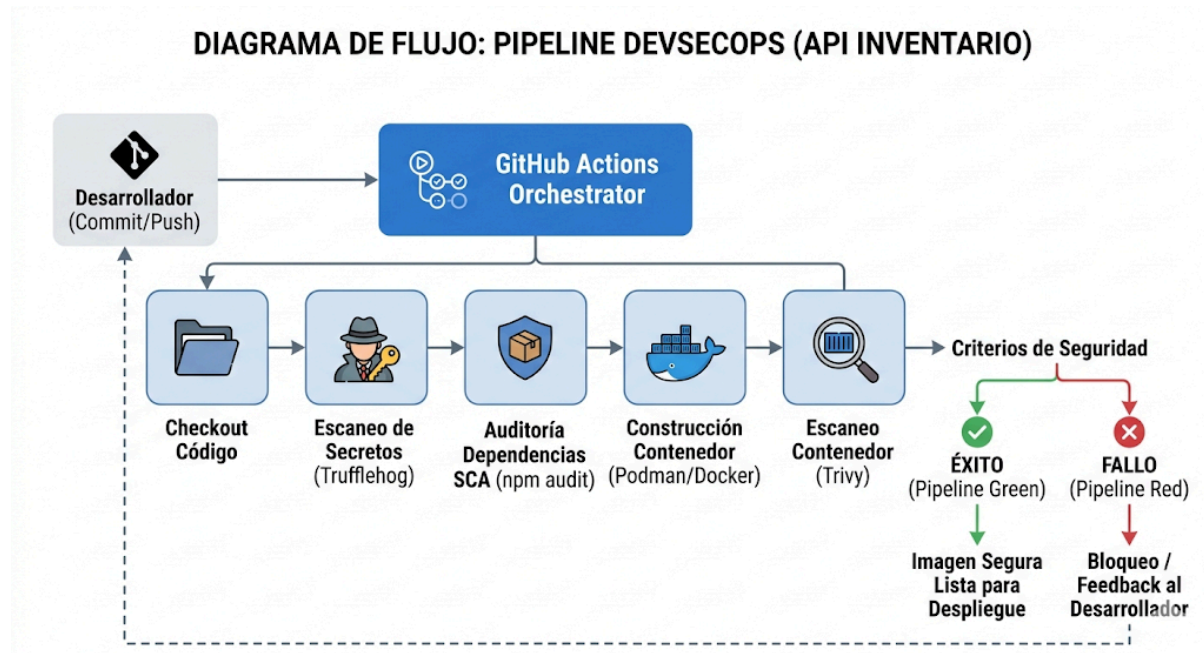
1. Introducción y Arquitectura del Pipeline

El presente proyecto consistió en la integración de controles de seguridad automatizados (DevSecOps) sobre una API REST orientada a la gestión logística y de inventario de equipos musicales y de audio. El objetivo principal fue desplazar la seguridad hacia la izquierda (Shift-Left), detectando vulnerabilidades antes del despliegue mediante un pipeline de Integración Continua (CI).

La arquitectura del pipeline se construyó utilizando GitHub Actions y consta de las siguientes fases automatizadas:

1. **Checkout:** Clonación del código fuente.
2. **Gestión de Secretos:** Análisis del historial y estado actual del código con Trufflehog.
3. **Construcción y SCA:** Instalación de dependencias de Node.js y ejecución de npm audit para Análisis de Composición de Software.
4. **Contenerización:** Construcción de la imagen de Docker/Podman (node:20-alpine).
5. **Seguridad de Contenedores:** Escaneo de la imagen resultante con Trivy para identificar vulnerabilidades (CVEs) en el sistema operativo base y librerías del sistema.

Diagrama



2. Gestión de Secretos

Para asegurar que ninguna credencial, token o contraseña fuera expuesta en el repositorio, se implementó la herramienta Trufflehog en el pipeline.

- **Configuración:** Se configuró para analizar todo el historial de commits (--only-verified), garantizando que no existan secretos hardcodeados en el código fuente.
- **Resultado:** El proyecto mantuvo un estándar de cero secretos en el código, manejando las configuraciones necesarias mediante variables de entorno en el servidor de despliegue.

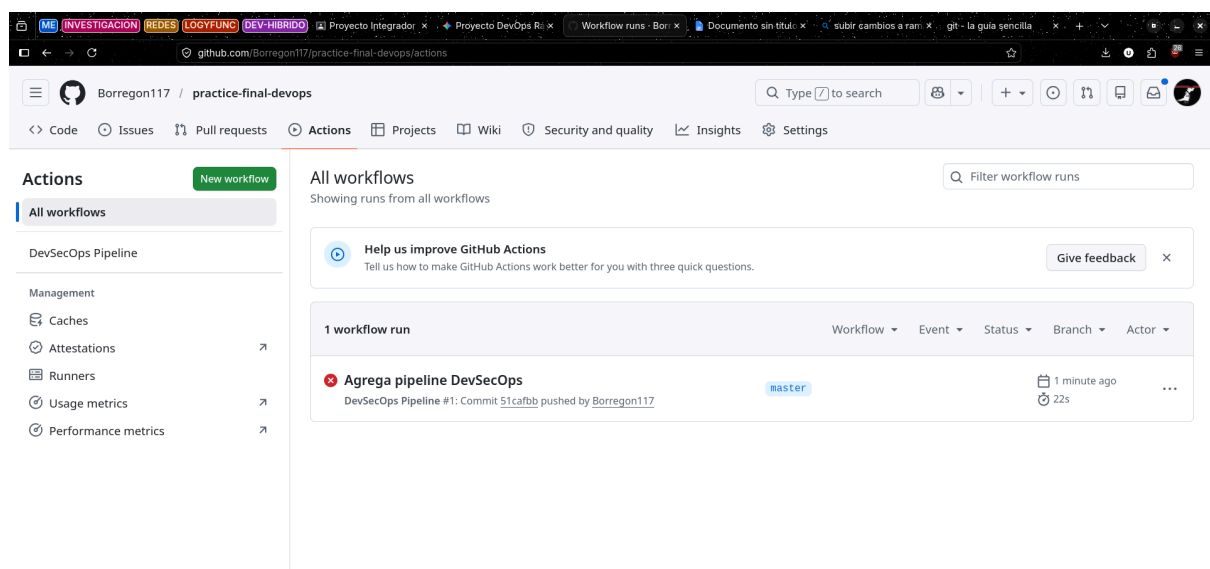
3. Escaneos de Seguridad y Corrección de Hallazgos

A lo largo del desarrollo, el pipeline bloqueó exitosamente el despliegue al detectar componentes vulnerables, obligando a su remediación.

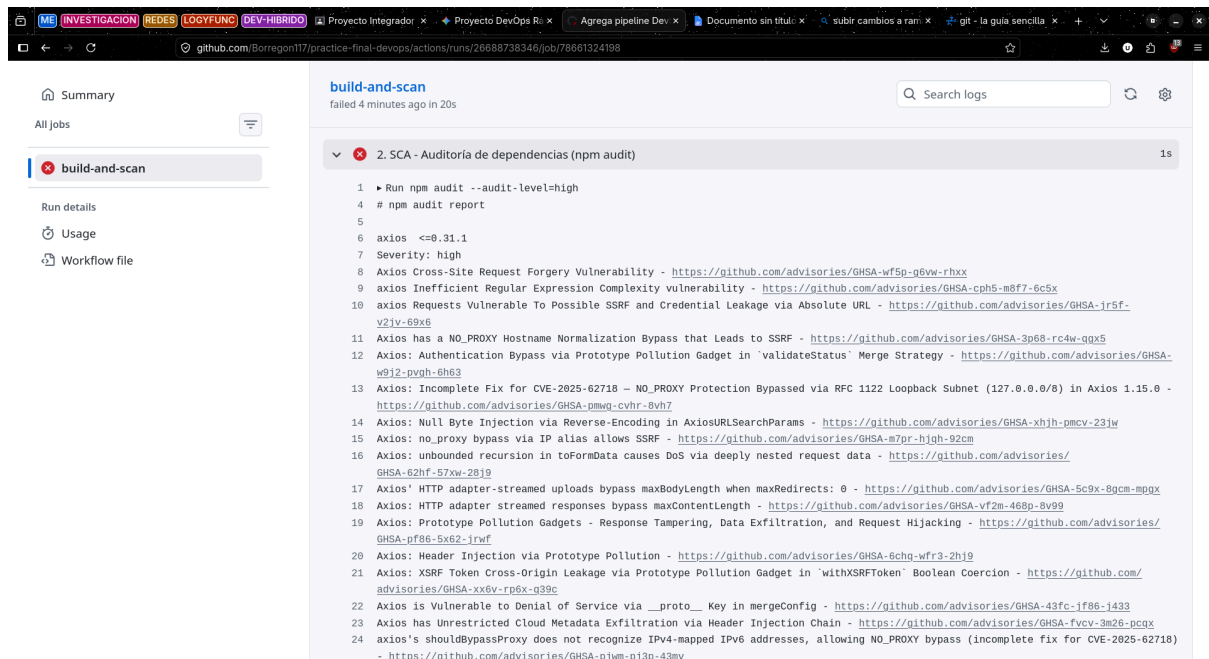
A. Análisis de Composición de Software (SCA) - npm audit

- **Hallazgo:** El escáner detectó una vulnerabilidad crítica en la dependencia axios (versión 0.21.1).
- **Remediación:** Se actualizó la dependencia a una versión segura (^1.6.8) en el archivo package.json, eliminando el riesgo de explotación en la capa de la aplicación.

Pipeline fallido en el push al repositorio (Github Actions):



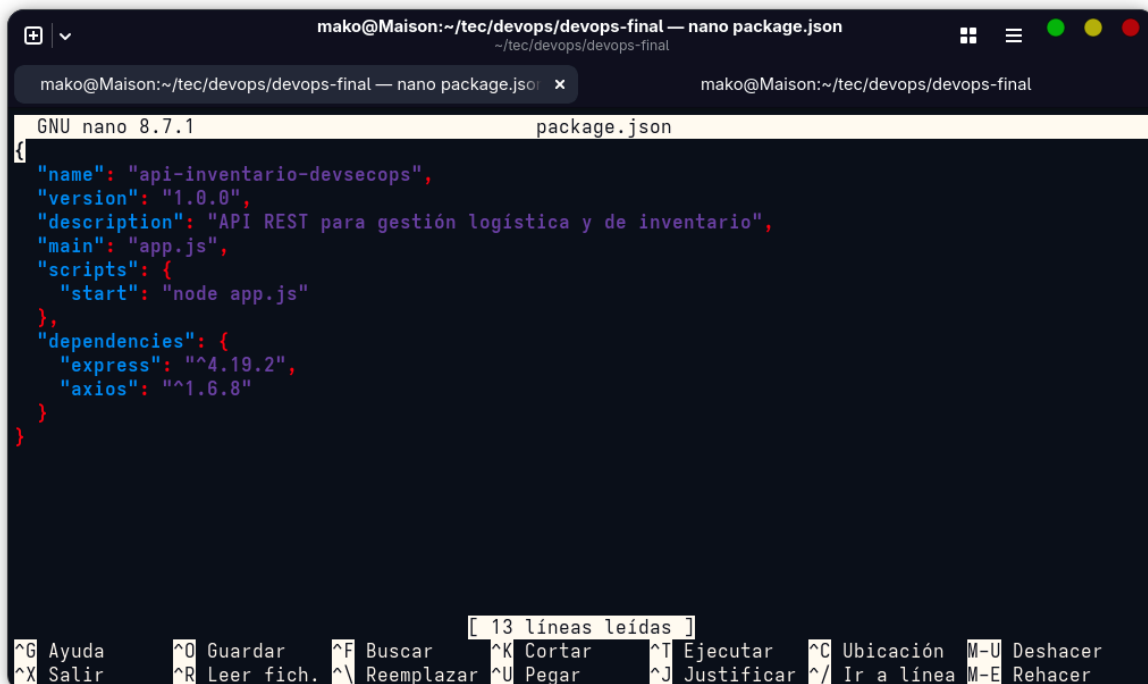
Detectando vulnerabilidades exactas (Logs):



The screenshot shows a GitHub Actions workflow run for a project named 'practice-final-devops'. The job 'build-and-scan' failed 4 minutes ago. The logs show an npm audit report with the following findings:

- 1 Run npm audit --audit-level=high
- 4 # npm audit report
- 6 axios <=0.31.1
- 7 Severity: high
- 8 Axios Cross-Site Request Forgery Vulnerability - <https://github.com/advisories/GHSA-wf5p-g6vw-rhxx>
- 9 axios Inefficient Regular Expression Complexity vulnerability - <https://github.com/advisories/GHSA-cph5-m8f7-6c5x>
- 10 axios Requests Vulnerable To Possible SSRF and Credential Leakage via Absolute URL - <https://github.com/advisories/GHSA-jrsf-v2jv-69x6>
- 11 Axios has a NO_PROXY Hostname Normalization Bypass that Leads to SSRF - <https://github.com/advisories/GHSA-3p68-rc4w-qxq5>
- 12 Axios: Authentication Bypass via Prototype Pollution Gadget in 'validateStatus' Merge Strategy - <https://github.com/advisories/GHSA-w9j2-pvqh-6h63>
- 13 Axios: Incomplete Fix for CVE-2025-62718 - NO_PROXY Protection Bypassed via RFC 1122 Loopback Subnet (127.0.0.0/8) in Axios 1.15.0 - <https://github.com/advisories/GHSA-pmmq-cvhr-8vh7>
- 14 Axios: Null Byte Injection via Reverse-Encoding in AxiosURLSearchParams - <https://github.com/advisories/GHSA-xhjh-pmcv-23jw>
- 15 Axios: no_proxy bypass via IP alias allows SSRF - <https://github.com/advisories/GHSA-87pr-hjqh-92cm>
- 16 Axios: unbounded recursion in toFormData causes DoS via deeply nested request data - <https://github.com/advisories/GHSA-pf86-5x62-irdf>
- 17 Axios' HTTP adapter-streamed uploads bypass maxBodyLength when maxRedirects: 0 - <https://github.com/advisories/GHSA-5c9x-8qcm-mpgx>
- 18 Axios: HTTP adapter streamed responses bypass maxContentLength - <https://github.com/advisories/GHSA-vf2m-468p-8v99>
- 19 Axios: Prototype Pollution Gadgets - Response Tampering, Data Exfiltration, and Request Hijacking - <https://github.com/advisories/GHSA-pf86-5x62-irdf>
- 20 Axios: Header Injection via Prototype Pollution - <https://github.com/advisories/GHSA-6chq-wfr3-2h19>
- 21 Axios: XSRF Token Cross-Origin Leakage via Prototype Pollution Gadget in 'withXSRFToken' Boolean Coercion - <https://github.com/advisories/GHSA-xx6v-rp6x-q39c>
- 22 Axios is Vulnerable to Denial of Service via __proto__ Key in mergeConfig - <https://github.com/advisories/GHSA-43fc-1f86-1433>
- 23 Axios has Unrestricted Cloud Metadata Exfiltration via Header Injection Chain - <https://github.com/advisories/GHSA-fvcv-3m26-pcqx>
- 24 axios's shouldBypassProxy does not recognize IPv4-mapped IPv6 addresses, allowing NO_PROXY bypass (incomplete fix for CVE-2025-62718) - <https://github.com/advisories/GHSA-pjwm-p13p-43mw>

Corrección, la versión especificada en el package.json que maneja Axios esta deprecated actualmente, modificando las dependencias:



The screenshot shows a terminal window with the nano package.json file. The file content is as follows:

```
{
  "name": "api-inventario-devsecops",
  "version": "1.0.0",
  "description": "API REST para gestión logística y de inventario",
  "main": "app.js",
  "scripts": {
    "start": "node app.js"
  },
  "dependencies": {
    "express": "^4.19.2",
    "axios": "^1.6.8"
  }
}
```

The terminal window also shows the GNU nano 8.7.1 editor interface and a list of keyboard shortcuts at the bottom.

B. Seguridad de Contenedores (Trivy)

- **Hallazgo:** Al escanear la imagen base node:20-alpine, Trivy detectó vulnerabilidades de nivel ALTO relacionadas con librerías internas del gestor de paquetes (npm, node-tar, minimatch, glob).
- **Estrategia de Remediación (Aceptación de Riesgo):** Dado que estas vulnerabilidades residen en las herramientas de construcción de la imagen base oficial y no en la lógica de negocio expuesta de la API, se aplicó una estrategia de aceptación de riesgo controlada. Se generó un archivo .trivyignore documentando los CVEs específicos (ej. CVE-2026-24842, CVE-2024-21538) para omitir falsos positivos y evitar bloqueos por dependencias del sistema operativo que aún no cuentan con parche oficial por parte del proveedor.

Nuevamente se procedió a hacer commit y subir cambios al repositorio, en Actions superó la prueba anterior pero se topó con un error en Seguridad de Contenedores (Trivy):

The screenshot shows a GitHub Actions workflow run for 'build-and-scan' that failed. The main part of the log displays the output of a Trivy scan on a Docker image. It identifies three high-severity vulnerabilities (ALTO) related to the node-tar package in version 7.5.8, 7.5.10, and 7.5.11. Each vulnerability is linked to a CVE (CVE-2026-26960, CVE-2026-29786, and CVE-2026-31802) and provides a URL to the NVD database for more details. The scan also mentions 'archive hardlink creation' and 'linkpath' as part of the affected components. At the bottom of the log, an error message states: 'Error: Process completed with exit code 1.' This is followed by a command to run 'rm -f trivy_envs.txt' and a shell prompt indicating the process failed.

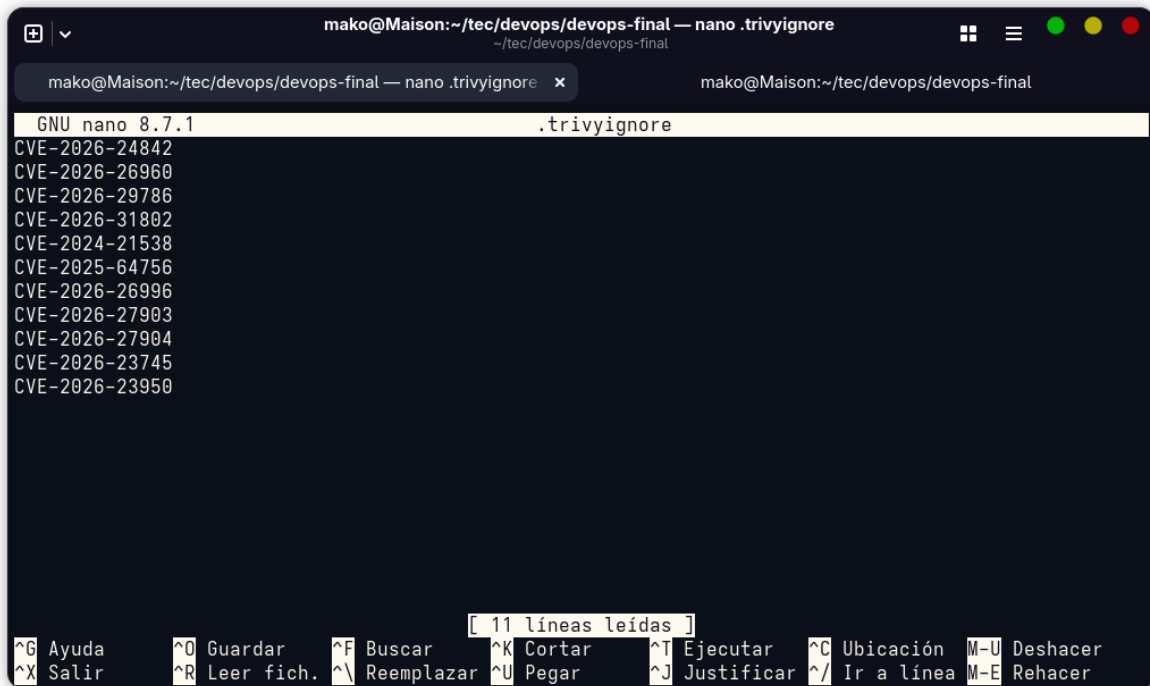
```
build-and-scan
failed 19 minutes ago in 42s

Summary
All jobs
build-and-scan
Run details
Usage
Workflow file

3. Seguridad de Contenedores (Trivy) 17s

930 | CVE-2026-26960 | 7.5.8
931 | node-tar: node-tar: Arbitrary file read/write via malicious |
932 | archive hardlink creation |
933 | https://avd.aquasec.com/nvd/cve-2026-26960 |
934 | CVE-2026-29786 | 7.5.10
935 | node-tar: hardlink path traversal via drive-relative |
936 | linkpath |
937 | https://avd.aquasec.com/nvd/cve-2026-29786 |
938 | CVE-2026-31802 | 7.5.11
939 | tar: tar: File overwrite via drive-relative symlink |
940 | traversal |
941 | https://avd.aquasec.com/nvd/cve-2026-31802 |
942 Error: Process completed with exit code 1.
943 Run rm -f trivy_envs.txt
944 rm -f trivy_envs.txt
945 shell: /usr/bin/bash --noprofile --norc -e -o pipefail {0}
946
```

Se solucionaron agregando un archivo `.trivyignore`, este ignorará ciertas políticas, se hace así debido a la versión de node que viene con la imagen de alpine (Node 20) que tiene vulnerabilidades que posteriormente fueron corregidas en nuevas versiones:

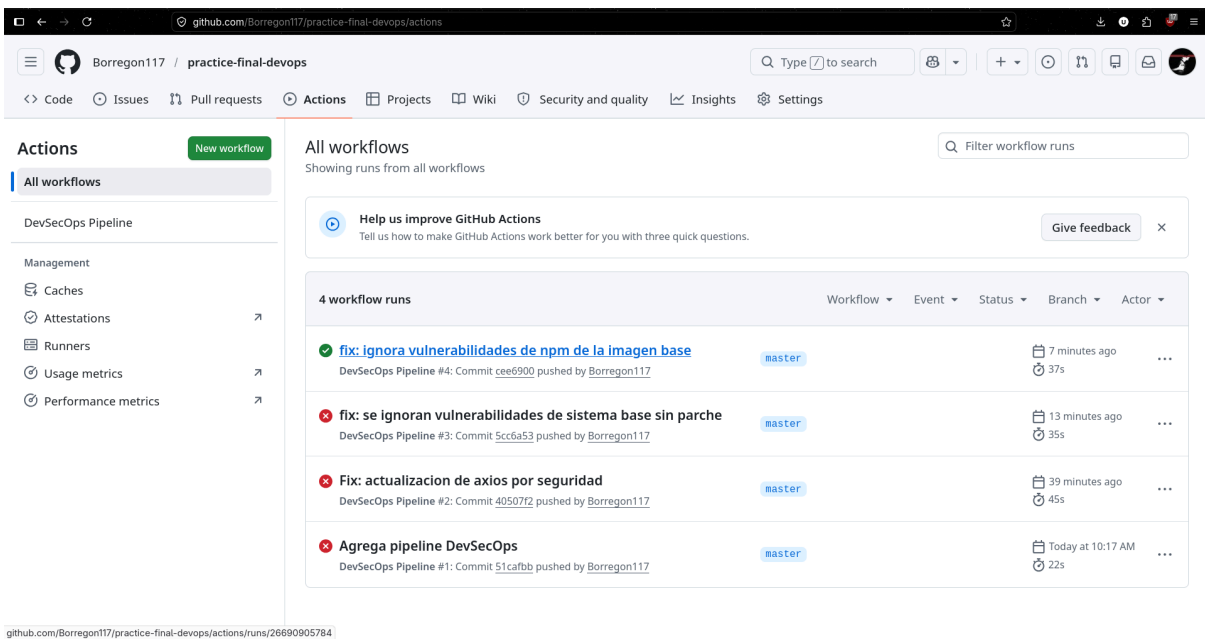


```
mako@Maison:~/tec/devops/devops-final — nano .trivyignore
~/tec/devops/devops-final
mako@Maison:~/tec/devops/devops-final — nano .trivyignore x mako@Maison:~/tec/devops/devops-final

GNU nano 8.7.1 .trivyignore
CVE-2026-24842
CVE-2026-26960
CVE-2026-29786
CVE-2026-31802
CVE-2024-21538
CVE-2025-64756
CVE-2026-26996
CVE-2026-27903
CVE-2026-27904
CVE-2026-23745
CVE-2026-23950

[ 11 líneas leídas ]
^G Ayuda      ^O Guardar    ^F Buscar     ^K Cortar     ^T Ejecutar   ^C Ubicación  M-U Deshacer
^X Salir      ^R Leer fich. ^\ Reemplazar ^U Pegar      ^J Justificar ^/ Ir a línea M-E Rehacer
```

Ahora con estos últimos cambios en el repositorio, ya hay luz verde:



Una captura con la información en detalle:

